Industrial Security (Bachelor)

Exercise Sheet – Section 07

Risk Management

Exercise 7.1 – Build a Risk Matrix

For a fictional gas compressor station:

1. Define five-point likelihood and consequence scales tailored to a midstream gas operator.
2. Brainstorm ten cyber risks and place each in the matrix.
3. Highlight the top three risks. Propose at least one mitigation per risk.

Exercise 7.2 – Cyber-HAZOP Mini-Workshop

The instructor provides a P&ID node (e.g. a heat exchanger). In groups of four:

1. Apply HAZOP guide words (No, More, Less, Reverse, As well as, Part of, Other than).
2. For each meaningful deviation, brainstorm a plausible *cyber* cause.
3. Identify existing safeguards and gaps.
4. Document findings in a HAZOP worksheet (one row per guide-word $\times$ parameter combination).

Exercise 7.3 – CCE Mini-Exercise

For the water-treatment plant from Section 03:

1. List the top three "worst-day" consequences (think public health, environmental release, downstream impact).
2. For each, identify the minimum set of assets that must fail simultaneously to realise it.
3. Propose one *engineering* change (not an IT control) that eliminates or radically reduces one of those consequences.

Exercise 7.4 – Risk Response Choice

For each, choose Avoid / Mitigate / Transfer / Accept and justify:

1. Legacy fax line into the order-entry system used by two customers per year.
2. OPC Classic (DCOM) link from L3 to L4, behind two firewalls.
3. Vendor remote-support tunnel using vendor-managed accounts.
4. Internet-exposed HMI used by a single offshore operator.

Exercise 7.5 – FAIR for the Board

Translate one risk from your matrix in Exercise 7.1 into a FAIR sketch:

- Estimate loss-event frequency (low / most likely / high, per year).

- Estimate loss magnitude (low / most likely / high, in EUR).
- Compute a rough Annualised Loss Expectancy range.
- Write a 3-sentence summary for the board that includes the ALE and the residual risk after one investment.

Exercise 7.6 – Insurance Baseline

Pick a cyber-insurance carrier and find the minimum control baseline they publish (MFA, EDR, backups, etc.). For each control on the list, mark whether a typical mid-sized water utility meets it. Identify the three biggest gaps and propose a closing roadmap.